8: CONFIGURING USER MANAGEMENT AND ROLE-BASED ACCESS CONTROL (RBAC) IN A ZOHO CREATOR APPLICATION

Aim:
To design, configure, and deploy a Role-Based Access Control (RBAC), Field-Level Security (FLS), and Customer Portal governance framework in Zoho Creator to protect confidential candidate data, restrict user permissions by role, and isolate internal HR workflows.

Theory
Enterprise HR applications manage sensitive candidate credentials, personal information, and financial data (such as salary expectations and internal manager feedback). Securing this data requires multi-layered governance:

- Role Hierarchy: Defines organizational reporting structures and top-down data visibility across management tiers (HR Director → HR Recruiter → Technical Interviewer)
- Profile Permissions: Regulates module-level CRUD (Create, Read, Edit, Delete) capabilities across forms, reports, and administrative tools.
- Field-Level Security (FLS): Controls the visibility and editability of individual form fields based on user profiles.
- Criteria-Based Access Control: Filters report and record access dynamically so users (such as Technical Interviewers) only access candidates explicitly assigned to them.
- Customer Portal Governance: Isolates public candidate application submission and status tracking interfaces from internal HR evaluation tools.

- Dynamic Script Governance (zoho.loginuser): Evaluates user credentials at runtime in Deluge to dynamically hide, disable, or restrict access to form fields based on the active user session.

Procedure

1. System Login & Application Access:
    - Log in to Zoho Creator and open the Automated Corporate Talent Acquisition and Interview Tracking System application.
2. Configure Role Hierarchy:
    - Navigate to Application Settings → Users & Permissions → Roles.
    - Establish the organizational hierarchy:

        HR Director (Top Level / Parent Role)

        HR Recruiter (Mid Level / Subordinate to HR Director)

        Technical Interviewer (Operational Level / Subordinate to HR Recruiter)
3. Establish Profile Permissions:
    - Go to Users & Permissions → Profiles and create three custom profiles:
    -

        HR Admin Profile: Full Create, Read, Edit, Delete permissions across all forms, reports, and settings.
        Recruiter Profile: Create and Edit permissions on Candidate Applications, Job Requisitions, and Interview Schedules (Delete disabled).
        Technical Interviewer Profile: Read-Only access on assigned candidate details and Edit permissions restricted to Interview Evaluation forms.

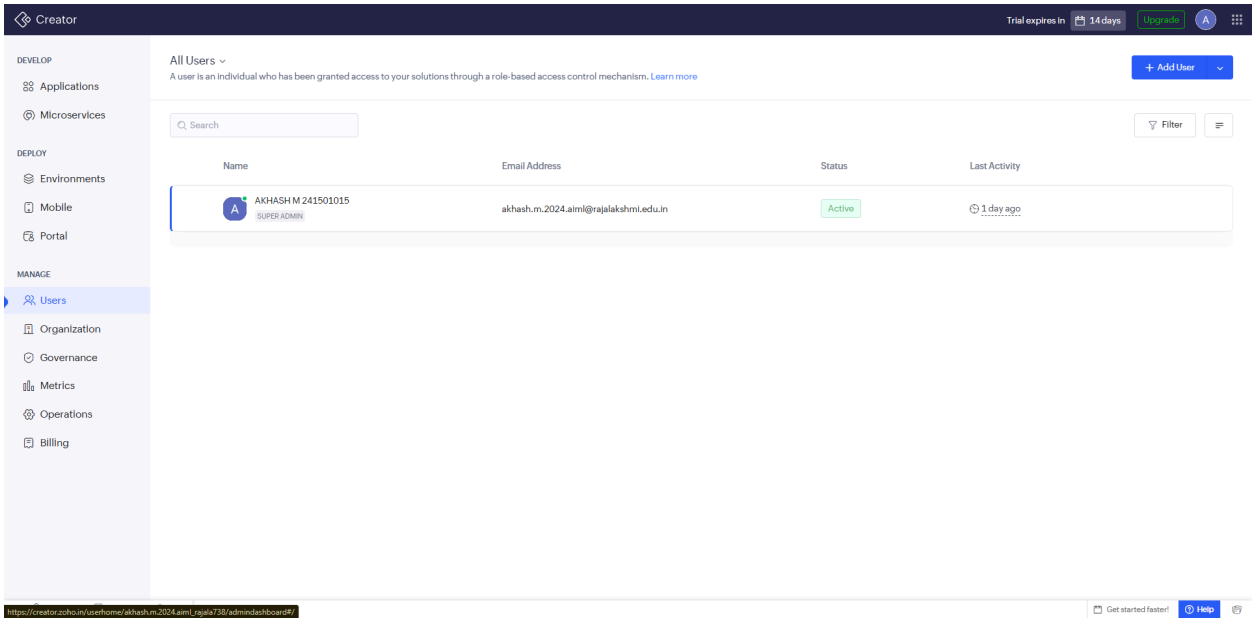
4. Apply Field-Level Security (FLS):
    - Open Candidate Application form in the Form Builder.
    - Select sensitive fields (e.g., Expected Salary, Current CTC, Internal HR Remarks).
    - Set field permissions for the Technical Interviewer profile to Hidden or Read-Only.
5. Set Up Data Sharing Rules:
    - Navigate to Application Settings → Data Sharing Rules.
    - Configure criteria-based sharing on candidate reports: Assigned_Interviewer == zoho.loginuser so interviewers only view candidate records assigned directly to them.
6. Enable Candidate Customer Portal:
    - Go to Application Settings → Portal User Permissions.
    - Enable the Customer Portal for external applicants to submit profiles and view status updates while isolating internal HR modules (Job Requisitions, Interview Evaluations).
7. Implement Dynamic Runtime Security (Deluge):
    - Open the Interview Evaluation form in Workflows → On Load.
    - Add a Deluge script using zoho.loginuser to evaluate session credentials and dynamically restrict unauthorized panel members:
      Snippet Code:

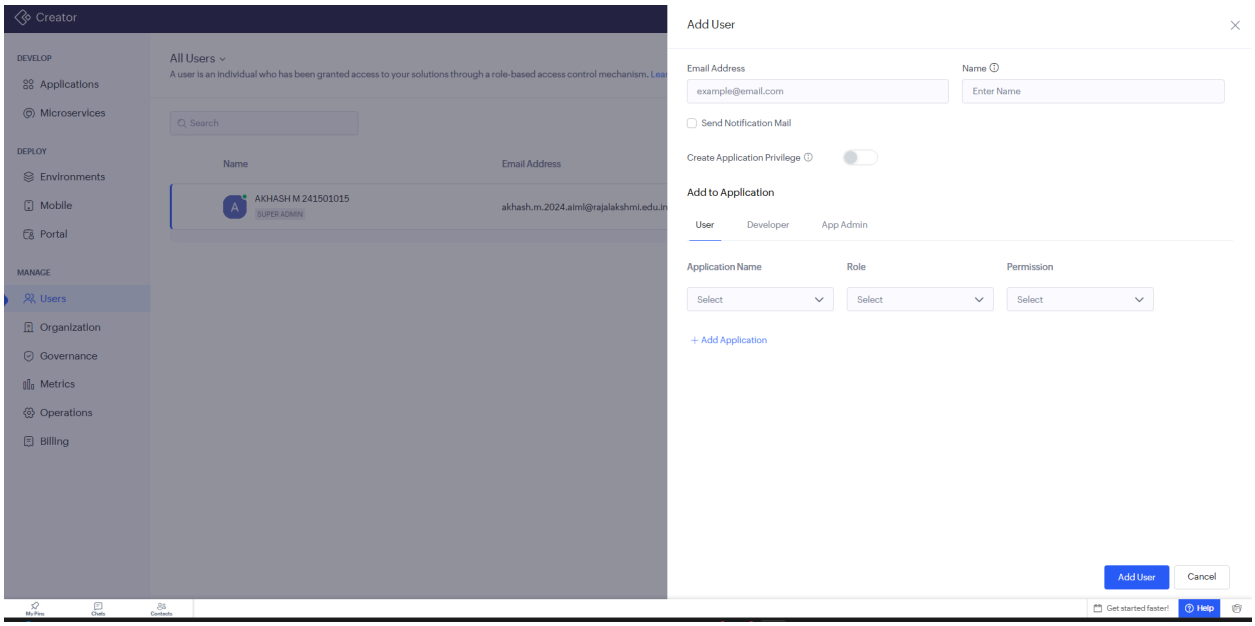
```
currentUser = zoho.loginuser;
if(currentUser != input.Assigned_Interviewer_Email)
{
   hide Final_Evaluation_Result;
   hide Recommended_CTC;
```

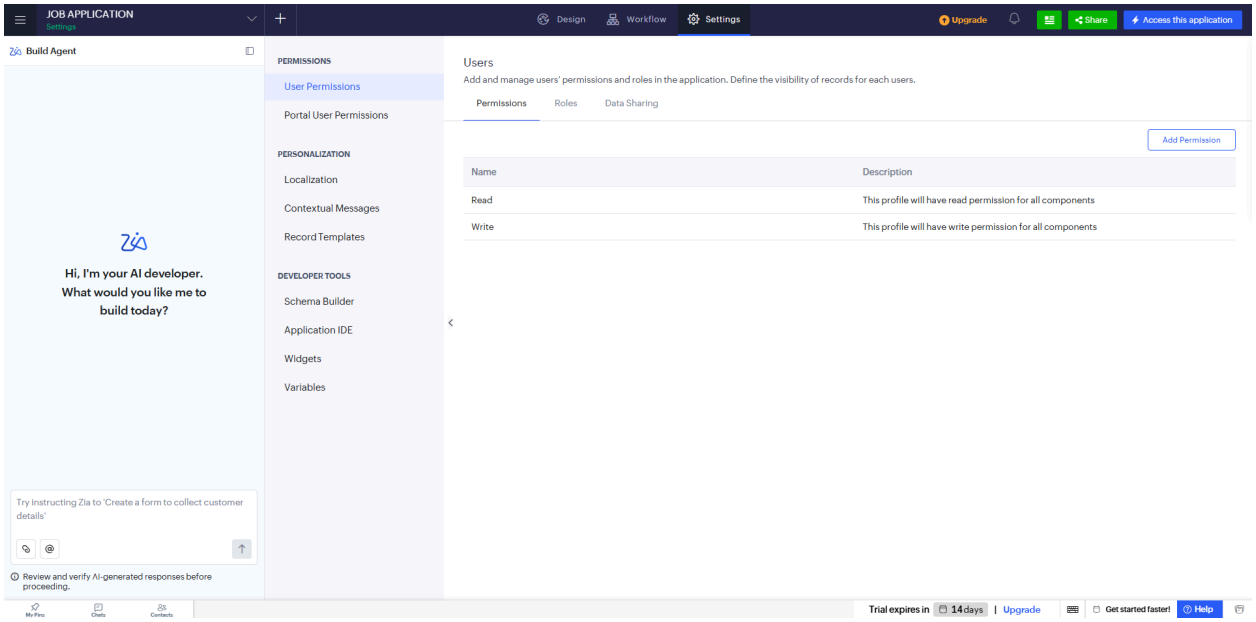
```
    alert "Access Restricted: You are not designated as the
assigned interviewer for this record.";
    disable Form_Submit;
}
```

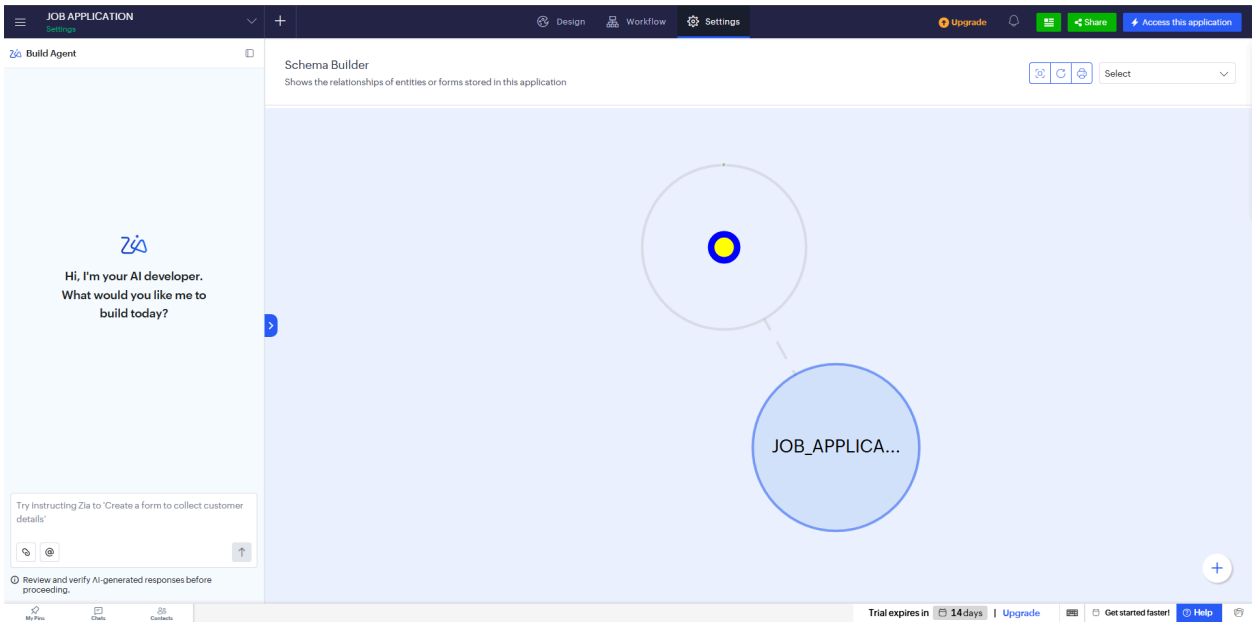
8. Perform Role-Based Access Control (RBAC) Testing:
    - Log in sequentially under four distinct user personas (HR Director, HR Recruiter, Technical Interviewer, and External Candidate) to verify form access, field visibility, and report filtering.
9. Inspect Security Execution & Audit Logs:
    - Open Application Settings → Developer Tools → Logs.
    - Review Audit Logs and Security Execution Logs to confirm that unauthorized access attempts were blocked with appropriate status codes.

Screenshots:


Creator
Trial expires in 14 days
Upgrade
DEVELOP
Applications
Microservices
DEPLOY
Environments
Mobile
Portal
MANAGE
Users
Organization
Governance
Metrics
Operations
Billing
All Users
A user is an individual who has been granted access to your solutions through a role-based access control mechanism. Learn more
+ Add User
Search
Filter
Name
Email Address
Status
Last Activity
AKHASH M 241501015
SUPER ADMIN
akhash.m.2024.aiml@rajalakshmi.edu.in
Active
1 day ago
https://creator.zoho.in/userhome/akhash.m.2024.aiml_rajala738/admindashboard#/
Get started faster!
Help


Creator
DEVELOP
Applications
Microservices
DEPLOY
Environments
Mobile
Portal
MANAGE
Users
Organization
Governance
Metrics
Operations
Billing
All Users
A user is an individual who has been granted access to your solutions through a role-based access control mechanism.
Search
Name
Email Address
AKHASH M 241501015
SUPER ADMIN
akhash.m.2024.aiml@rajalakshmi.edu.in
Add User
Email Address
example@email.com
Name
Enter Name
Send Notification Mail
Create Application Privilege
Add to Application
User
Developer
App Admin
Application Name
Role
Permission
Select
Select
Select
+ Add Application
Add User
Cancel
Get started faster!
Help


JOB APPLICATION
Settings
Design
Workflow
Settings
Upgrade
Share
Access this application
Build Agent
PERMISSIONS
User Permissions
Portal User Permissions
PERSONALIZATION
Localization
Contextual Messages
Record Templates
DEVELOPER TOOLS
Schema Builder
Application IDE
Widgets
Variables
Users
Add and manage users' permissions and roles in the application. Define the visibility of records for each users.
Permissions
Roles
Data Sharing
Add Permission
Name
Description
Read
This profile will have read permission for all components
Write
This profile will have write permission for all components
Hi, I'm your AI developer.
What would you like me to build today?
Try instructing Zia to 'Create a form to collect customer details'
Review and verify AI-generated responses before proceeding.
Trial expires in 14 days | Upgrade
Get started faster!
Help


JOB APPLICATION
Settings
Design
Workflow
Settings
Upgrade
Share
Access this application
Build Agent
Schema Builder
Shows the relationships of entities or forms stored in this application
Select
JOB_APPLICA...
Hi, I'm your AI developer.
What would you like me to build today?
Try instructing Zia to 'Create a form to collect customer details'
Review and verify AI-generated responses before proceeding.
Trial expires in 14 days | Upgrade
Get started faster!
Help

Result

The Role-Based Access Control (RBAC) and Security architecture in Zoho Creator is fully operational:

- Role hierarchies and profile permissions successfully restrict module access according to administrative tiers.
- Sensitive candidate salary details and internal remarks are protected using Field-Level Security and zoho.loginuser runtime scripts.
- External candidates are safely isolated via the Customer Portal without access to internal HR evaluation systems.
- Audit and security execution logs verify that unauthorized access attempts were blocked and recorded accurately.